

Databehandleraftale

Mellem

Forsvarsministeriets Materiel- og Indkøbsstyrelse

CVR 16287180

Lautrupbjerg 1-5

2750 Ballerup

Danmark

(herefter FMI)

og

[Navn]

CVR [CVR-nummer]

[Adresse]

[Postnummer og by]

[Land]

(herefter Databehandleren)

om behandling af personoplysninger i forbindelse med levering, drift og vedligeholdelse et internetbaseret bookingsystem til Forsvarets Puljekøretøjer

1. Indhold

2. Præambel	3
3. FMI' s rettigheder og forpligtelser	4
4. Databehandleren handler efter instruks	4
5. Fortrolighed	4
6. Fortegnelse.....	4
7. Behandlingssikkerhed	5
8. Anvendelse af underdatabehandlere.....	6
9. Overførsel til tredjelande eller internationale organisationer	7
10. Bistand til FMI.....	7
11. Underretning om brud på persondatasikkerheden	9
12. Sletning og returnering af oplysninger	9
13. Revision, herunder inspektion	10
14. Forrang og tvister	10
15. Parternes aftale om andre forhold	10
16. Ikrafttræden og ophør.....	10
17. Kontaktpersoner hos FMI og databehandleren	11
Bilag A Oplysninger om behandlingen	13
Bilag B Underdatabehandlere	14
Bilag C Instruks vedrørende behandling af personoplysninger.....	14
Bilag D Parternes regulering af andre forhold	17
Bilag E Underretning om brud på persondatasikkerheden	18
Bilag F Sikkerhedskrav til databehandling	19

2. Præambel

1. Disse Bestemmelser fastsætter databehandlerens rettigheder og forpligtelser, når denne foretager behandling af personoplysninger på vegne af FMI.
2. Disse bestemmelser er udformet med henblik på parternes efterlevelse af artikel 28, stk. 3, i Europa-Parlamentets og Rådets forordning (EU) 2016/679 af 27. april 2016 om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger og om fri udveksling af sådanne oplysninger og om ophævelse af direktiv 95/46/EF (databeskyttelsesforordningen).
3. I forbindelse med levering, drift, support og vedligeholdelse af et internetbaseret bookingsystem til Forsvarets Puljekøretøjer behandler databehandleren personoplysninger på vegne af FMI i overensstemmelse med disse Bestemmelser.
4. Bestemmelserne har forrang i forhold til eventuelle tilsvarende bestemmelser i andre aftaler mellem parterne.
5. Der hører seks bilag til disse Bestemmelser, og bilagene udgør en integreret del af Bestemmelserne.
6. Bilag A indeholder nærmere oplysninger om behandlingen af personoplysninger, herunder om behandlingens formål og karakter, typen af personoplysninger, kategorierne af registrerede og varighed af behandlingen.
7. Bilag B indeholder FMI's betingelser for databehandlerens brug af underdatabehandlere og en liste af underdatabehandlere, som FMI har godkendt brugen af.
8. Bilag C indeholder FMI's instruks for så vidt angår databehandlerens behandling af personoplysninger, en beskrivelse af de sikkerhedsforanstaltninger, som databehandleren som minimum skal gennemføre, og hvordan der føres tilsyn med databehandleren og eventuelle underdatabehandlere.
9. Bilag D indeholder bestemmelser vedrørende andre aktiviteter, som ikke er omfattet af Bestemmelserne.
10. Bilag E indeholder en skabelon og instruks for Databehandlers underretning om brud på persondatasikkerheden.
11. Bilag F indeholder en oversigt over påkrævet sikkerhedsforanstaltninger til behandlingen af personoplysninger.
12. Bestemmelserne med tilhørende bilag skal opbevares skriftligt, herunder elektronisk, af begge parter.
13. Disse Bestemmelser frigør ikke databehandleren fra forpligtelser, som databehandleren er pålagt efter databeskyttelsesforordningen eller enhver anden lovgivning.

3. FMI's rettigheder og forpligtelser

1. FMI er ansvarlig for at sikre, at behandlingen af personoplysninger sker i overensstemmelse med databeskyttelsesforordningen (se forordningens artikel 24), databeskyttelsesbestemmelser i anden EU-ret eller medlemsstaternes¹ nationale ret og disse Bestemmelser.
2. FMI har ret og pligt til at træffe beslutninger om, til hvilke(t) formål og med hvilke hjælpemidler, der må ske behandling af personoplysninger.
3. FMI er ansvarlig for, blandt andet, at sikre, at der er et behandlingsgrundlag for behandlingen af personoplysninger, som databehandleren instrueres i at foretage.

4. Databehandleren handler efter instruks

1. Databehandleren må kun behandle personoplysninger efter dokumenteret instruks fra FMI, medmindre det kræves i henhold til EU-ret eller medlemsstaternes nationale ret, som databehandleren er underlagt. Denne instruks skal være specificeret i bilag A og C. Efterfølgende instruks kan også gives af FMI, mens der sker behandling af personoplysninger, men instruksen skal altid være dokumenteret og opbevares skriftligt, herunder elektronisk, sammen med disse Bestemmelser.
2. Databehandleren underretter omgående FMI, hvis en instruks efter vedkommendes mening er i strid med denne forordning eller databeskyttelsesbestemmelser i anden EU-ret eller medlemsstaternes nationale ret.

5. Fortrolighed

1. Databehandleren må kun give adgang til personoplysninger, som behandles på FMI's vegne, til personer, som er underlagt databehandlerens instruktionsbeføjelser, som har forpligtet sig til fortrolighed eller er underlagt en passende lovbestemt tavshedspligt, og kun i det nødvendige omfang. Listen af personer, som har fået tildelt adgang, skal løbende gennemgås. På baggrund af denne gennemgang kan adgangen til personoplysninger lukkes, hvis adgangen ikke længere er nødvendig, og personoplysningerne skal herefter ikke længere være tilgængelige for disse personer.
2. Databehandleren skal efter anmodning fra FMI kunne påvise, at de pågældende personer, som er underlagt databehandlerens instruktionsbeføjelser, er underlagt ovennævnte tavshedspligt.

6. Fortegnelse

1. Databehandleren skal føre en fortegnelse over alle kategorier af behandlinger, der foretages på vegne af FMI jf. databeskyttelsesforordningens artikel 30, stk. 2.

¹ Henvisninger til "medlemsstat" i disse bestemmelser skal forstås som en henvisning til "EØS medlemsstater".

7. Behandlingssikkerhed

1. Databeskyttelsesforordningens artikel 32 fastslår, at FMI og databehandleren, under hensyntagen til det aktuelle tekniske niveau, implementeringsomkostningerne og den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder, gennemfører passende tekniske og organisatoriske foranstaltninger for at sikre et beskyttelsesniveau, der passer til disse risici.

FMI skal vurdere risiciene for fysiske personers rettigheder og frihedsrettigheder som behandlingen udgør og gennemføre foranstaltninger for at imødegå disse risici. Afhængig af deres relevans kan det omfatte:

- a. Pseudonymisering og kryptering af personoplysninger
 - b. evne til at sikre vedvarende fortrolighed, integritet, tilgængelighed og robusthed af behandlingssystemer og -tjenester
 - c. evne til rettidigt at genoprette tilgængeligheden af og adgangen til personoplysninger i tilfælde af en fysisk eller teknisk hændelse
 - d. en procedure for regelmæssig afprøvning, vurdering og evaluering af effektiviteten af de tekniske og organisatoriske foranstaltninger til sikring af behandlingssikkerhed.
2. Efter forordningens artikel 32 skal databehandleren – uafhængigt af FMI – også vurdere risiciene for fysiske personers rettigheder som behandlingen udgør og gennemføre foranstaltninger for at imødegå disse risici. Med henblik på denne vurdering skal FMI stille den nødvendige information til rådighed for databehandleren som gør vedkommende i stand til at identificere og vurdere sådanne risici.
 3. Derudover skal databehandleren bistå FMI med vedkommendes overholdelse af FMI's forpligtelse efter forordningens artikel 32, ved bl.a. at stille den nødvendige information til rådighed for FMI vedrørende de tekniske og organisatoriske sikkerhedsforanstaltninger, som databehandleren allerede har gennemført i henhold til forordningens artikel 32, og al anden information, der er nødvendig for FMI's overholdelse af sin forpligtelse efter forordningens artikel 32.

Hvis imødegåelse af de identificerede risici – efter FMI's vurdering – kræver gennemførelse af yderligere foranstaltninger end de foranstaltninger, som databehandleren allerede har gennemført, skal de yderligere foranstaltninger, der skal gennemføres listes i bilag F.

8. Anvendelse af underdatabehandlere

1. Databehandleren skal opfylde de betingelser, der er omhandlet i databeskyttelsesforordningens artikel 28, stk. 2, og stk. 4, for at gøre brug af en anden databehandler (en underdatabehandler).
2. Databehandleren må således ikke gøre brug af en underdatabehandler til opfyldelse af disse Bestemmelser uden forudgående specifik skriftlig godkendelse fra FMI.
3. Databehandleren må kun gøre brug af underdatabehandlere med FMI's forudgående specifikke skriftlige godkendelse. Databehandleren skal indgive anmodningen om en specifik godkendelse mindst 30 (tredive) dage inden anvendelsen af den pågældende underdatabehandler. Listen over underdatabehandlere, som FMI allerede har godkendt, fremgår af bilag B.
4. Når databehandleren gør brug af en underdatabehandler i forbindelse med udførelse af specifikke behandlingsaktiviteter på vegne af FMI, skal databehandleren, gennem en kontrakt eller andet retligt dokument i henhold til EU-retten eller medlemsstaternes nationale ret, pålægge underdatabehandleren de samme databeskyttelsesforpligtelser som dem, der fremgår af disse Bestemmelser, hvorved der navnlig stilles de fornødne garantier for, at underdatabehandleren vil gennemføre de tekniske og organisatoriske foranstaltninger på en sådan måde, at behandlingen overholder kravene i disse Bestemmelser og databeskyttelsesforordningen.

Databehandleren er derfor ansvarlig for at kræve, at underdatabehandleren som minimum overholder databehandlerens forpligtelser efter disse Bestemmelser og databeskyttelsesforordningen.

5. Underdatabehandleraftale(r) og eventuelle senere ændringer hertil sendes – efter FMI's anmodning herom – i kopi til FMI, som herigennem har mulighed for at sikre sig, at tilsvarende databeskyttelsesforpligtelser som følger af disse Bestemmelser er pålagt underdatabehandleren. Bestemmelser om kommercielle vilkår, som ikke påvirker det databeskyttelsesretlige indhold af underdatabehandleraftalen, skal ikke sendes til FMI.
6. Databehandleren skal i sin aftale med underdatabehandleren indføre FMI som begunstiget tredjemand, således at FMI i tilfælde af at databehandleren faktisk eller retligt set er ophørt med at eksistere eller i tilfælde af databehandlerens konkurs, har ret til at opsigte underdatabehandleraftalen og instruere underdatabehandleren i at slette eller tilbagelevere personoplysningerne.
7. Hvis underdatabehandleren ikke opfylder sine databeskyttelsesforpligtelser, forbliver databehandleren fuldt ansvarlig over for FMI for opfyldelsen af underdatabehandlerens forpligtelser. Dette påvirker ikke de registreredes rettigheder, der følger af databeskyttelsesforordningen, herunder særligt forordningens artikel 79 og 82, over for FMI og databehandleren, herunder underdatabehandleren.

9. Overførsel til tredjelande eller internationale organisationer

1. Enhver overførsel af personoplysninger til tredjelande eller internationale organisationer må kun foretages af databehandleren på baggrund af dokumenteret instruks herom fra FMI og skal altid ske i overensstemmelse med databeskyttelsesforordningens kapitel V.
2. Hvis overførsel af personoplysninger til tredjelande eller internationale organisationer, som databehandleren ikke er blevet instrueret i at foretage af FMI, kræves i henhold til EU-ret eller medlemsstaternes nationale ret, som databehandleren er underlagt, skal databehandleren underrette FMI om dette retlige krav inden behandling, medmindre den pågældende ret forbyder en sådan underretning af hensyn til vigtige samfundsmæssige interesser.
3. Uden dokumenteret instruks fra FMI kan databehandleren således ikke inden for rammerne af disse Bestemmelser:
 - a. overføre personoplysninger til en dataansvarlig eller databehandler i et tredjeland eller en international organisation
 - b. overlade behandling af personoplysninger til en underdatabehandler i et tredjeland
 - c. behandle personoplysningerne i et tredjeland
4. FMI's instruks vedrørende overførsel af personoplysninger til et tredjeland, herunder det eventuelle overførselsgrundlag i databeskyttelsesforordningens kapitel V, som overførslen er baseret på, skal angives i bilag C.6.
5. Disse Bestemmelser skal ikke forveksles med standardkontraktbestemmelser som omhandlet i databeskyttelsesforordningens artikel 46, stk. 2, litra c og d, og disse Bestemmelser kan ikke udgøre et grundlag for overførsel af personoplysninger som omhandlet i databeskyttelsesforordningens kapitel V.

10. Bistand til FMI

1. Databehandleren bistår, under hensyntagen til behandlingens karakter, så vidt muligt FMI ved hjælp af passende tekniske og organisatoriske foranstaltninger med opfyldelse af FMI's forpligtelse til at besvare anmodninger om udøvelsen af de registreredes rettigheder som fastlagt i databeskyttelsesforordningens kapitel III.

Dette indebærer, at databehandleren så vidt muligt skal bistå FMI i forbindelse med, at FMI skal sikre overholdelsen af:

- a. oplysningspligten ved indsamling af personoplysninger hos den registrerede
- b. oplysningspligten, hvis personoplysninger ikke er indsamlet hos den registrerede
- c. indsigtsheden
- d. retten til berigtigelse

- e. retten til sletning ("retten til at blive glemt")
 - f. retten til begrænsning af behandling
 - g. underretningspligten i forbindelse med berigtigelse eller sletning af personoplysninger eller begrænsning af behandling
 - h. retten til dataportabilitet
 - i. retten til indsigelse
 - j. retten til ikke at være genstand for en afgørelse, der alene er baseret på automatisk behandling, herunder profilering
2. I tillæg til databehandlerens forpligtelse til at bistå FMI i henhold til Bestemmelse 7.3., bistår databehandleren endvidere, under hensyntagen til behandlingens karakter og de oplysninger, der er tilgængelige for databehandleren, FMI med:
- a. FMI's forpligtelse til uden unødigt forsinkelse og om muligt senest 72 timer, efter at denne er blevet bekendt med det, at anmelde brud på persondatasikkerheden til den kompetente tilsynsmyndighed, Datatilsynet, medmindre at det er usandsynligt, at bruddet på persondatasikkerheden indebærer en risiko for fysiske personers rettigheder eller frihedsrettigheder
 - b. FMI's forpligtelse til uden unødigt forsinkelse at underrette den registrerede om brud på persondatasikkerheden, når bruddet sandsynligvis vil medføre en høj risiko for fysiske personers rettigheder og frihedsrettigheder
 - c. FMI's forpligtelse til forud for behandlingen at foretage en analyse af de påtænkte behandlingsaktiviteters konsekvenser for beskyttelse af personoplysninger (en konsekvensanalyse)
 - d. FMI's forpligtelse til at høre den kompetente tilsynsmyndighed, Datatilsynet, inden behandling, såfremt en konsekvensanalyse vedrørende databeskyttelse viser, at behandlingen vil føre til høj risiko i mangel af foranstaltninger truffet af FMI for at begrænse risikoen.
3. Parterne skal i bilag C angive de fornødne tekniske og organisatoriske foranstaltninger, hvormed databehandleren skal bistå FMI samt i hvilket omfang og udstrækning. Det gælder for de forpligtelser, der følger af Bestemmelse 10.1. og 10.2.
4. Databehandleren forpligter sig endvidere til, uden unødige forsinkelser at orientere FMI om:
- a. enhver anmodning om videregivelse af personoplysninger omfattet af Databehandleraftalen fra en myndighed, medmindre orienteringen af FMI er eksplicit forbudt ved lov, f.eks. i medfør af regler, der har til formål at sikre fortroligheden af en retshåndhævende myndigheds efterforskning,
 - b. enhver anmodning fra tilsynsmyndigheden vedrørende behandling af personoplysninger omfattet af Databehandleraftalen,

- c. enhver anmodning modtaget direkte fra den registrerede, eller den registreredes tredjemand/repræsentant, om at anvende deres rettigheder.

11. Underretning om brud på persondatasikkerheden

1. Databehandleren underretter uden unødigt forsinkelse FMI efter at være blevet opmærksom på, at der er sket et brud på persondatasikkerheden.
2. Databehandlerens underretning til FMI skal om muligt ske senest 24 (fireogtyve) timer efter, at denne er blevet bekendt med bruddet, sådan at FMI kan overholde sin forpligtelse til at anmelde bruddet på persondatasikkerheden til den kompetente tilsynsmyndighed, jf. databeskyttelsesforordningens artikel 33.
3. I overensstemmelse med Bestemmelse 10.2.a skal databehandleren bistå FMI med at foretage anmeldelse af bruddet til den kompetente tilsynsmyndighed. Det betyder, at databehandleren skal bistå med at tilvejebringe nedenstående information, som ifølge artikel 33, stk. 3, skal fremgå af FMI's anmeldelse af bruddet til den kompetente tilsynsmyndighed:
 - a. karakteren af bruddet på persondatasikkerheden, herunder, hvis det er muligt, kategorierne og det omtrentlige antal berørte registrerede samt kategorierne og det omtrentlige antal berørte registreringer af personoplysninger
 - b. de sandsynlige konsekvenser af bruddet på persondatasikkerheden
 - c. de foranstaltninger, som FMI har truffet eller foreslår truffet for at håndtere bruddet på persondatasikkerheden, herunder, hvis det er relevant, foranstaltninger for at begrænse dets mulige skadevirkninger.
4. Parterne skal i bilag C angive den information, som databehandleren skal tilvejebringe i forbindelse med sin bistand til FMI i dennes forpligtelse til at anmelde brud på persondatasikkerheden til den kompetente tilsynsmyndighed.
5. Databehandlerens underretning skal foretages ved brug af den vedhæftede skabelon for underretning, der følger af Bilag E.
6. Databehandleren må hverken offentligt eller til tredjepart kommunikere et brud uden forudgående skriftlig aftale med FMI om indholdet af en sådan kommunikation, medmindre databehandleren har en retslig forpligtelse hertil.

12. Sletning og returnering af oplysninger

1. Ved ophør af tjenesterne vedrørende behandling af personoplysninger, er databehandleren forpligtet til at tilbagelevere alle personoplysningerne og slette eksisterende kopier, medmindre EU-retten eller medlemsstaternes nationale ret foreskriver opbevaring af personoplysningerne. Tilbagelevering af personoplysninger er vederlagsfri for FMI og skal være i et maskinlæsbart format.

13. Revision, herunder inspektion

1. Databehandleren stiller alle oplysninger, der er nødvendige for at påvise overholdelsen af databeskyttelsesforordningens artikel 28 og disse Bestemmelser, til rådighed for FMI og giver mulighed for og bidrager til revisioner, herunder inspektioner, der foretages af FMI eller en anden revisor, som er bemyndiget af FMI.
2. Procedurene for FMI's revisioner, herunder inspektioner, med databehandleren og underdatabehandlere er nærmere angivet i Bilag C.7. og C.8.
3. Databehandleren er forpligtet til at give tilsynsmyndigheder, som efter gældende lovgivningen har adgang til FMI's eller databehandlerens faciliteter, eller repræsentanter, der optræder på tilsynsmyndighedens vegne, adgang til databehandlerens fysiske faciliteter mod behørig legitimation.

14. Forrang og tvister

1. I tilfælde af uoverensstemmelse mellem bestemmelserne i databehandleraftalen og bestemmelserne i hovedaftalen eller andre skriftlige eller mundtlige aftaler indgået mellem parterne vedrørende behandling af persondata, skal bestemmelserne i databehandleraftalen have forrang, medmindre strengere krav til behandlingssikkerheden er fastsat i hovedaftalen, hovedaftalens bilag eller anden aftale mellem parterne.
2. Såfremt der opstår en tvist mellem parterne i anledning af databehandleraftalen, skal parterne loyalt søge at løse tvisten og indlede forhandlinger med henblik på at håndtere denne. Såfremt parterne ikke kan blive enige, løses eventuelle tvister i overensstemmelse med punkt 16.2

15. Parternes aftale om andre forhold

1. Parterne kan aftale andre bestemmelser vedrørende tjenesten vedrørende behandling af personoplysninger om f.eks. erstatningsansvar, så længe disse andre bestemmelser ikke direkte eller indirekte strider imod Bestemmelserne eller forringer den registreredes grundlæggende rettigheder og frihedsrettigheder, som følger af databeskyttelsesforordningen.

16. Ikrafttræden og ophør

1. Bestemmelserne træder i kraft på datoen for begge parters underskrift af Hovedaftalen eller begge parters underskrift af denne aftale.
2. Begge parter kan kræve Bestemmelserne genforhandlet, hvis lovændringer eller uhensigtsmæssigheder i Bestemmelserne giver anledning hertil. Databehandleren skal ved ændringer uden unødigt forsinkelse sikre, at eventuelle underdatabehandlere tillige forpligtes af ændringerne.
3. Bestemmelserne er gældende, så længe tjenesten vedrørende behandling af personoplysninger varer. I denne periode kan Bestemmelserne ikke opsiges, medmindre

andre bestemmelser, der regulerer levering af tjenesten vedrørende behandling af personoplysninger, aftales mellem parterne.

4. Hvis levering af tjenesterne vedrørende behandling af personoplysninger ophører, og personoplysningerne er slettet eller returneret til FMI i overensstemmelse med Bestemmelse 12.1 og Bilag C.4, kan Bestemmelserne opsiges med skriftlig varsel af begge parter.

FMI er til enhver tid berettiget til at ændre i Bilag A og Bilag C uden forudgående accept fra Databehandleren ved fremsendelse af nyt bilag til Databehandleren. Alle ændringer foretaget i bilag A og bilag C vil blive givet til databehandleren af FMI i skriftligt (elektronisk) format. Alle ændringer skal dog ske inden for de udbudsretlige rammer.

5. Underskrift

På vegne af FMI

Navn	Morten Gammelmark Yde
Stilling	Chef for Kapacitetscenter Transport og Lægemidler
Telefonnummer	+45 2933 3153
E-mail	FMI-LA-CHJTL@mil.dk

Underskrift	_____	Dato	_____
-------------	-------	------	-------

På vegne af databehandleren

Navn	[NAVN]
Stilling	[STILLING]
Telefonnummer	[TELEFONNUMMER]
E-mail	[E-MAIL]

Underskrift	_____	Dato	_____
-------------	-------	------	-------

17. Kontaktpersoner hos FMI og databehandleren

1. Parterne kan kontakte hinanden via nedenstående kontaktpersoner.
2. Parterne er forpligtet til løbende at orientere hinanden om ændringer vedrørende kontaktpunkter/kontaktpersoner.

Forsvarsministeriets Materiel- og Indkøbsstyrelse

Navn	Morten Gammelmark Yde
Stilling	Chef for Kapacitetscenter Transport og Lægemidler
Telefonnummer	+45 2933 3153
E-mail	FMI-LA-CHJTL@mil.dk

Databehandleren [indsæt firmaets fulde navn]

Navn	[NAVN]
Stilling	[STILLING]
Telefonnummer	[TELEFONNUMMER]
E-mail	[E-MAIL]

Bilag A Oplysninger om behandlingen

A.1. Formålet med databehandlerens behandling af personoplysninger på vegne af FMI

At Databehandleren på vegne af FMI indsamler, registrerer og opbevarer personoplysninger til brug for levering, drift og vedligeholdelse et internetbaseret bookingsystem til Forsvarets Puljekøretøjer.

A.2. Databehandlerens behandling af personoplysninger på vegne af FMI drejer sig primært om (karakteren af behandlingen)

At Databehandleren på vegne af FMI foretager følgende behandlinger af personoplysninger ved levering, drift og vedligeholdelse et internetbaseret bookingsystem til Forsvarets Puljekøretøjer. Indsamling, registrering, organisering, systematisering, opbevaring, tilpasning, ændring, genfinding, søgning, og formidling.

A.3. Behandlingen omfatter følgende typer af personoplysninger om de registrerede

Følgende typer af personoplysninger vil blive behandlet af Databehandleren:

- Almindelige oplysninger
 - Medarbejdersnummer,
 - Arbejds-mæssige tilhørsforhold,
 - Telefonnummer (både privat og arbejde),
 - E-mailadresse (både privat og arbejde),
 - Geo-lokation,

Herudover kan behandlingen omfatte samtlige typer af almindelige personoplysninger, der tilvebringes i fritekstfelter.

A.4. Behandlingen omfatter følgende kategorier af registrerede

- Forsvarets ansatte.

A.5. Databehandlerens behandling af personoplysninger på vegne af FMI kan påbegyndes efter disse Bestemmelser i krafttræden. Behandlingen har følgende varighed:

Behandlingen er ikke tidsbegrænset og varer, indtil aftalen opsiges eller ophæves af en af parterne.

Bilag B Underdatabehandlere

B.1. Godkendte underdatabehandlere

Ved Bestemmelsernes ikrafttræden har FMI godkendt brugen af følgende underdatabehandlere

NAVN	CVR-NR.	ADRESSE	HOSTING LOCATION	BESKRIVELSE AF BEHANDLING

Ved Bestemmelsernes ikrafttræden har FMI godkendt brugen af ovennævnte underdatabehandlere for den beskrevne behandlingsaktivitet. Databehandleren må ikke – uden FMI's skriftlige godkendelse – gøre brug af en underdatabehandler til en anden behandlingsaktivitet end den beskrevne og aftalte eller gøre brug af en anden underdatabehandler til denne behandlingsaktivitet.

B.2. Varsel for godkendelse af underdatabehandlere

Databehandleren må alene gøre brug af underdatabehandlere efter forudgående **specifik** skriftlig godkendelse fra FMI. Databehandlerens anmodning herom skal være FMI i hænde minimum 30 (tredive) dage, før anvendelsen eller ændringen skal træde i kraft. FMI kan alene nægte godkendelse, såfremt FMI har rimelige, konkrete årsager hertil.

Bilag C Instruks vedrørende behandling af personoplysninger

C.1. Behandlingens genstand/instruks

Databehandlerens behandling af personoplysninger på vegne af FMI sker ved, at databehandleren udfører følgende:

At Databehandleren skal drifte, vedligeholde og supportere Systemet.

C.2. Behandlingssikkerhed

Under hensyntagen til behandlingens karakter, omfang, sammenhæng og formål, såvel som den udarbejdet risikovurdering af behandlingen beskrevet i Bilag A, er databehandlerens behandling af personoplysninger på vegne af FMI blevet vurderet til lav, hvorfor der skal etableres et tilsvarende sikkerhedsniveau for at kunne imødegå risiciene.

Databehandleren er således – under alle omstændigheder og som minimum - forpligtet til at implementere og vedligeholde de tekniske og organisatoriske sikkerhedsforanstaltninger op-listet i Bilag F. Databehandleren er ligeledes forpligtet til at kunne stille dokumentation til råd-dighed for FMI der påviser, at sikkerhedsforanstaltningerne i) er implementeret, ii) genbesø-ges og vedligeholdes og iii) overholdes.

I forlængelse af de i Bilag F op-listet sikkerhedsforanstaltninger er Databehandleren forpligtet til at udføre deres egen risikovurdering og berettiget til at træffe beslutninger om, hvorvidt yderligere tekniske og organisatoriske sikkerhedsforanstaltninger, skal gennemføres for at etablere det nødvendige (og aftalte) sikkerhedsniveau. Disse yderligere foranstaltninger skal godkendes af FMI.

C.3 Bistand til FMI

Databehandleren skal så vidt muligt – inden for det nedenstående omfang og udstrækning – bistå FMI i overensstemmelse med Bestemmelse 10.1 og 10.2 ved at gennemføre følgende tekniske og organisatoriske foranstaltninger op-listet i Bilag F.

C.4 Opbevaringsperiode/sletterutine

Personoplysninger opbevares i hele aftalens levetid, hvorefter de slettes hos databehandle-ren.

Ved ophør af tjenesten vedrørende behandling af personoplysninger, skal databehandleren enten slette eller tilbagelevere personoplysningerne i overensstemmelse med bestemmelse 12.1, medmindre FMI – efter underskriften af disse bestemmelser – har ændret FMI oprinde-lige valg. Sådanne ændringer skal være dokumenteret og opbevares skriftligt, herunder elek-tronisk, i tilknytning til bestemmelserne.

C.5 Lokalitet for behandling

Behandling af de af Bestemmelserne omfattede personoplysninger kan ikke uden FMI's for-udgående skriftlige godkendelse ske på andre lokaliteter end følgende:

- [Angiv på hvilken lokation, behandlingen finder sted] [Angiv, hvilken databehandler eller underdatabehandler, der anvender lokation]
- [Angiv på hvilken lokation, behandlingen finder sted] [Angiv, hvilken databehandler eller underdatabehandler, der anvender lokation]]

C.6 Instruks vedrørende overførsel af personoplysninger til tredjelande

Hvis FMI ikke i disse Bestemmelser eller efterfølgende giver en dokumenteret instruks vedrø-rende overførsels af personoplysninger til et tredjeland, er databehandleren ikke berettiget til inden for rammerne af disse Bestemmelser at foretage sådanne overførsler.

C.7 Procedurer for FMI's revisioner, herunder inspektioner, med behandlingen af per-sonoplysninger, som er overladt til databehandleren

Databehandleren skal én gang årligt for egen regning indhente en inspektionsrapport fra en uafhængig tredjepart vedrørende databehandlerens overholdelse af databeskyttelsesforordningen, databeskyttelsesbestemmelser i anden EU-ret eller medlemsstaternes nationale ret og disse Bestemmelser.

Inspektionsrapporter fremsendes uden unødigt forsinkelse til FMI til orientering. FMI kan anfægte rammerne for og/eller metoden i rapporten og kan i sådanne tilfælde anmode om en ny inspektionsrapport under andre rammer og/eller under anvendelse af anden metode.

Baseret på resultaterne af rapporten, er FMI berettiget til at anmode om gennemførelse af yderligere foranstaltninger med henblik på at sikre overholdelsen af databeskyttelsesforordningen, databeskyttelsesbestemmelser i anden EU-ret eller medlemsstaternes nationale ret og disse Bestemmelser.

FMI eller en repræsentant for FMI har herudover adgang til at foretage inspektioner, herunder fysiske inspektioner, med lokaliteterne hvorfra databehandleren foretager behandling af personoplysninger, herunder fysiske lokaliteter og systemer, der benyttes til eller i forbindelse med behandlingen. Sådanne inspektioner kan gennemføres, når FMI finder det nødvendigt.”

FMI's eventuelle udgifter i forbindelse med en fysisk inspektion afholdes af FMI selv. Databehandleren er dog forpligtet til at afsætte de ressourcer (hovedsageligt den tid), der er nødvendig(e) for, at FMI kan gennemføre sin inspektion.

C.8 Procedurer for revisioner, herunder inspektioner, med behandling af personoplysninger, som er overladt til underdatabehandlere

Databehandleren skal én gang årligt for egen regning indhente en [revisionserklæring/inspektionsrapport] fra en uafhængig tredjepart vedrørende underdatabehandlerens overholdelse af databeskyttelsesforordningen, databeskyttelsesbestemmelser i anden EU-ret eller medlemsstaternes nationale ret og disse Bestemmelser.

[Revisionserklæringen/Inspektionsrapporten] fremsendes uden unødigt forsinkelse til FMI til orientering. FMI kan anfægte rammerne for og/eller metoden i [revisionserklæringen/inspektionsrapporten] og kan i sådanne tilfælde anmode om en ny [revisionserklæring/inspektionsrapport] under andre rammer og/eller under anvendelse af anden metode.

Baseret på resultaterne af [revisionserklæringen/inspektionsrapporten], er FMI berettiget til at anmode om gennemførelse af yderligere foranstaltninger med henblik på at sikre overholdelsen af databeskyttelsesforordningen, databeskyttelsesbestemmelser i anden EU-ret eller medlemsstaternes nationale ret og disse Bestemmelser.

Databehandleren eller en repræsentant for databehandleren har herudover adgang til at foretage inspektioner, herunder fysiske inspektioner, med lokaliteterne hvorfra underdatabehandleren foretager behandling af personoplysninger, herunder fysiske lokaliteter og systemer, der benyttes til eller i forbindelse med behandlingen. Sådanne inspektioner kan gennemføres, når databehandleren (eller FMI) finder det nødvendigt.

Dokumentation for sådanne inspektioner fremsendes uden unødigt forsinkelse til FMI til orientering. FMI kan anfægte rammerne for og/eller metoden af inspektionen og kan i sådanne tilfælde anmode om gennemførelsen af en ny inspektion under andre rammer og/eller under anvendelse af anden metode.

FMI kan – hvis det findes nødvendigt – vælge at initiere og deltage på en fysisk inspektion hos underdatabehandleren. Dette kan blive aktuelt, hvis FMI vurderer, at databehandlerens inspektion hos underdatabehandleren ikke har givet FMI tilstrækkelig sikkerhed for, at behandlingen hos underdatabehandleren sker i overensstemmelse med databeskyttelsesforordningen, databeskyttelsesbestemmelser i anden EU-ret eller medlemsstaternes nationale ret og disse Bestemmelser.

FMI's eventuelle deltagelse i en inspektion hos underdatabehandleren ændrer ikke ved, at databehandleren også herefter har det fulde ansvar for underdatabehandlerens overholdelse af databeskyttelsesforordningen, databeskyttelsesbestemmelser i anden EU-ret eller medlemsstaternes nationale ret og disse Bestemmelser.

Databehandlerens og underdatabehandlerens eventuelle udgifter i forbindelse med en fysisk inspektion af underdatabehandlerens lokaliteter er FMI uvedkommende – uanset om FMI har initieret og deltaget i en sådan inspektion.

Bilag D Parternes regulering af andre forhold

D.1. Erstatningspligt

Uanset, hvad der følger af Hovedaftalen, skal Databehandleren skadesløsholde FMI, såfremt FMI bliver mødt med krav fra tredjemand som følge af, at Databehandleren i sin rolle som Databehandler eller Databehandlerens eventuelle underdatabehandlere i deres rolle som underdatabehandler har overtrådt den til enhver tid gældende databeskyttelsesretlige lovgivning. Databehandleren hæfter kun for skader, hvis Databehandleren eller dennes eventuelle underdatabehandlere ikke har opfyldt sine/deres forpligtelser som databehandler og/eller underdatabehandler, som det følger af den til enhver tid gældende lovgivning, eller hvis Databehandleren som Databehandler eller dennes eventuelle underdatabehandlere som underdatabehandler har undladt at følge eller handlet i strid med FMI's lovlige instruks.

Forpligtelsen til at skadesløsholde FMI er ikke omfattet af en evt. aftalt erstatningsmaksimering i Hovedaftalen. Databehandlerens forpligtelse til at skadesløsholde FMI efter nærværende afsnit gælder ikke for bøder pålagt FMI i medfør af Databeskyttelsesforordningens artikel 83 eller sanktioner fastlagt i Danmark i overensstemmelse med Databeskyttelsesforordningens artikel 84.

Uanset, hvad der følger af Hovedaftalen, skal FMI skadesløsholde Databehandleren, såfremt Databehandleren bliver mødt med krav fra tredjemand som følge af, at FMI i sin rolle som dataansvarlig har overtrådt den til enhver tid gældende databeskyttelsesretlige lovgivning. FMI hæfter kun for skader, hvis FMI ikke har opfyldt sine forpligtelser som Dataansvarlig, som det følger af den til enhver tid gældende lovgivning.

Forpligtelsen til at skadesløsholde Databehandleren er ikke omfattet af en evt. aftalt erstatningsmaksimering i Hovedaftalen. FMI's forpligtelse til at skadesløsholde Databehandleren efter nærværende afsnit gælder ikke for bøder pålagt Databehandleren i medfør af Databeskyttelsesforordningens artikel 83 eller sanktioner fastlagt i Danmark i overensstemmelse med Databeskyttelsesforordningens artikel 84.

D.2. [Eventuelle andre forhold, som reguleres særskilt]

Bilag E Underretning om brud på persondatasikkerheden

I tilfælde af brud på persondatasikkerhed skal følgende information indgives til FMI:

Dato og tid:	Brud på persondatasikkerheden blev konstateret den [dato], klokken [klokkeslæt].
Omstændighederne ved bruddet på persondatasikkerheden:	Bruddet skyldes [omstændighederne ved bruddet på persondatasikkerheden].
Karakteren/arten af bruddet:	På nuværende tidspunkt bemærkes det, at [Indsæt information om karakteren/arten af bruddet. Såfremt det er muligt at fastslå følgende: 1) Kategorier og det omtrentlige antal registrerede impliceret; 2) Kategorier og det omtrentlige antal persondataoplysninger impliceret.]
Andre oplysninger:	På nuværende tidspunkt bemærkes det, at [Angiv andre oplysninger om bruddet på persondatasikkerheden, der kan være brugbare for FMI's vurdering af indvirkningen af bruddet].
Handlinger truffet:	Af hensyn til at begrænse omfanget af og konsekvenserne ved bruddet, har vi indtil videre [foranstaltninger truffet af [Databehandlerens navn] for at imødegå bruddet på persondatasikkerheden, herunder foranstaltninger truffet for at begrænse eventuelle skadevirkninger].
Kontaktperson hos Databehandleren:	[Kontaktoplysninger, herunder information på Databehandlerens eventuelle DPO].

Oplysningerne skal sendes til FMI's kontaktperson som angivet i Databehandleraftalens punkt 17.

Bilag F Sikkerhedskrav til databehandling
(ISO 27001 refererer til ISO 27001/2023)

X = Gældende

Intet = Ikke gældende

Organisatoriske foranstaltninger

Krav-ID	Krav	ISO27001-reference	Lavt risikoniveau	Mellem risikoniveau	Højt risikoniveau
K1	<u>ISO 27001: Bilag A:</u> Informationssikkerhedspolitik og emnespecifikke politikker skal defineres, godkendes af ledelsen, offentliggøres, kommunikeres til og anerkendes af relevante medarbejdere og relevante interessenter og vurderes med planlagte mellemrum samt hvis der sker væsentlige ændringer. <u>FMI fortolkning:</u> Databehandleren skal have implementeret politikker for sikringen af hhv. privatliv og informationssikkerhed. Politikkerne skal være godkendt af ledelsen, offentliggjort og kommunikeret til, og anerkendt af, Databehandlerens medarbejdere og interessenter. Databehandleren skal ligeledes sikre, at politikkerne vurderes og revideres med planlagt mellemrum (mindst én gang om året) og at væsentlige ændringer bliver kommunikeret til FMI forud ændringens ikrafttræden.	5.1	X	X	X
K2	<u>ISO 27001: Bilag A:</u> Roller og ansvar for informationssikkerhed skal defineres og allokeres i overensstemmelse med organisationens behov. <u>FMI fortolkning:</u> Databehandleren skal have klarlagt og dokumenteret de individuelle ansattes roller og ansvarsområder for hhv. persondatabeskyttelse og informationssik-	5.2	X	X	X

	kerhed i forbindelse med Databehand- lerens behandling af personoplysninger på vegne af FMI.				
K3	Konfliktende opgaver og konfliktende ansvarsområder skal adskilles.	5.3	X	X	X
K4	<u>ISO 27001: Bilag A:</u> Ledelsen skal kræve, at alle medarbej- dere efterlever informationssikkerhed i overensstemmelse med organisatio- nens fastlagte informationssikkerheds- politik, emnespecifikke politikker og procedurer. <u>FMI fortolkning:</u> Databehandleren skal kunne sikre, at samtlige medarbejdere i Databehandle- rens organisation efterlever de imple- menterede persondatabeskyttelseslige- og informationssikkerhedskrav, som Databehandleren og forpligtet sig til i forbindelse med indgåelsen af denne databehandlertaftale samt Databehand- lerens interne politikker.	5.4	X	X	X
K5	Organisationen skal etablere og vedli- geholde kontakt med relevante myndig- heder. (Omfattet af Databehandlertaftalen)	5.5	X	X	X
K6	<u>ISO 27001: Bilag A:</u> Organisationen skal etablere og vedli- geholde passende kontakt med særlige interessegrupper eller an- dre specialistfora omkring sikkerhed og faglige organisationer. <u>FMI fortolkning:</u> Databehandleren skal etablere og ved- ligeholde passende kontakt med FMI.	5.6	X	X	X
K7	<u>ISO 27001: Bilag A:</u> Information om informationssikkerheds- trusler skal indsamles og analyseres med henblik på at frembringe underret- ning om trusler.	5.7	X	X	X

	<u>FMI fortolkning:</u> Databehandleren skal indsamle og analysere informationer om persondata- tabeskyttelse- og informationssikker- hedstrusler med henblik på at under- rette dets ansatte og FMI omkring disse trusler, herunder hvordan Data- behandleren har tænkt sig at imøde- komme disse trusler.				
K8	<u>ISO 27001: Bilag A:</u> Informationssikkerhed skal integreres i projektstyringen. <u>FMI fortolkning:</u> Informationssikkerhed og persondata- beskyttelse skal integreres i projektsty- ringen.	5.8	X	X	X
K9	<u>ISO 27001: Bilag A:</u> Der skal udarbejdes og vedligeholdes en fortegnelse over information og un- derstøttende aktiver, herunder ejere. <u>FMI fortolkning:</u> Databehandleren skal udarbejde en fortegnelse over dens behandling(er) af personoplysninger på vegne af FMI i overensstemmelse med databeskyttel- sesforordningens art. 30, stk. 2. Forteg- nelsen skal hertil indeholde informatio- ner omkring de understøttende aktiver, herunder hvem der er system- og pro- cesejere.	5.9	X	X	X
K10	<u>ISO 27001: Bilag A:</u> Regler for acceptabel brug og procedu- rer til håndtering af information og un- derstøttende aktiver skal identificeres, dokumenteres og implementeres. <u>FMI fortolkning:</u> Databehandleren skal indføre regler for acceptabel brug og procedurer til hånd- tering af informationer og personoplys- ninger og understøttende aktiver skal	5.10	X	X	X

	hertil identificeres, dokumenteres og implementeres.				
K11	<u>ISO 27001: Bilag A:</u> Medarbejdere og andre interessenter skal aflevere alle de af organisationens aktiver, de har i deres besiddelse, når deres ansættelse, kontrakt eller aftale ophører eller ændrer karakter. <u>FMI fortolkning:</u> Databehandlerens medarbejdere skal aflevere alle deres arbejdsrelateret aktiver, de har i deres besiddelse, når deres ansættelse, kontrakt eller aftale ophører eller arbejdsopgaver væsentligt ændrer karakter således, at medarbejderen ikke længere indgår i Databehandlerens behandling af FMI's delte informationer og personoplysninger.	5.11	X	X	X
K12	<u>ISO 27001: Bilag A:</u> Information skal klassificeres i henhold til organisationens informationssikkerhedsbehov på grundlag af fortrolighed, integritet, tilgængelighed og relevante krav fra interessenter. <u>FMI fortolkning:</u> Databehandleren skal foretage en intern klassificering af FMI-delte informationer og personoplysninger med henblik på sikre fortroligheden, integriteten og tilgængeligheden af disse informationer.	5.12	X	X	X
K13	<u>ISO 27001: Bilag A:</u> Der skal udarbejdes og implementeres et passende sæt af procedurer til mærkning af information i overensstemmelse med det informationsklassifikationssystem, som organisationen har vedtaget. <u>FMI fortolkning:</u> Der skal udarbejdes og implementeres et passende sæt af procedurer til	5.13		X	X

	mærkning af informationer og personoplysninger i samtlige af Databehandlerens systemer.				
K14	<u>ISO 27001: Bilag A:</u> Der skal være etableret regler eller procedurer for eller aftaler om overførsel af information for alle former for overførselsfaciliteter i organisationen og mellem organisationen og andre parter. <u>FMI fortolkning:</u> Der skal være etableret regler, procedurer for samt aftaler om overførsel/videregivelse/deling af informationer og personoplysninger i Databehandlerens organisation og mellem Databehandleren og andre parter.	5.14	X	X	X
K15	<u>ISO 27001: Bilag A:</u> Der skal fastlægges og implementeres regler for styring af fysisk og logisk adgang til information og understøttende aktiver på grundlag af forretnings- og informationssikkerhedskrav. <u>FMI fortolkning:</u> Databehandleren skal fastlægge og implementere passende regler for styring af fysisk og logisk adgang til information og personoplysninger og understøttende aktiver på grundlag af det i Bilag C oplyste risikoniveau. Disse regler og styringsforslag skal godkendes af FMI. .	5.15	X	X	X
K16	Identiteters samlede livscyklus skal styres.	5.16	X	X	X
K17	Tildeling og styring af autentifikationsoplysninger skal ske i form af en ledelsesproces, herunder rådgivning af medarbejdere om passende håndtering af autentifikationsoplysninger.	5.17	X	X	X
K18	<u>ISO 27001: Bilag A:</u> Adgangsrettigheder til information og understøttende aktiver skal tilvejebringes, vurderes, ændres og fjernes i	5.18	X	X	X

	overensstemmelse med organisationens emnespecifikke politik og regler for administration af adgang. <u>FMI fortolkning:</u> Databehandleren skal sikre, at dets ansattes adgangsrettigheder revurderes med planlagte mellemrum, og at disse rettigheder enten opdateres, fjernes eller tilvejebringes i overensstemmelse med de(n) ansattes rolle i behandlingen af de FMI-delte informationer og personoplysninger.				
K19	<u>ISO 27001: Bilag A:</u> Processer og procedurer skal defineres og implementeres for at styre de informationssikkerhedsrisici, der er forbundet med brugen af leverandørens produkter eller tjenester. <u>FMI fortolkning:</u> Databehandleren skal implementere processer og procedurer for at styre de informationssikkerheds- og persondataskyttelsesrisici, der er forbundet med brugen af dets egne, såvel som evt. underleverandørers, produkter eller tjenester.	5.19	X	X	X
K20	Relevante informationssikkerhedskrav skal fastlægges og aftales med hver enkelt leverandør på grundlag af typen af leverandørforhold.	5.20	X	X	X
K21	<u>ISO 27001: Bilag A:</u> Processer og procedurer skal defineres og implementeres for at styre de informationssikkerhedsrisici, der er forbundet med forsyningskæden for IKT-produkter og -tjenester. <u>FMI fortolkning:</u> Processer og procedurer skal defineres og implementeres for at styre de informationssikkerhedsrisici, der er forbun-	5.21	X	X	X

	det med forsyningskæden for informations- og kommunikationsteknologiske (IKT)-produkter og -tjenester.				
K22	<u>ISO 27001: Bilag A:</u> Organisationen skal regelmæssigt overvåge, vurdere, evaluere og styre ændringer i leverandørers informationssikkerhedspraksis og levering af ydelser. <u>FMI fortolkning:</u> Databehandleren skal regelmæssigt overvåge, vurdere, evaluere og styre ændringer i dets egen, samt dets leverandørs, informationssikkerheds- og persondatabeskyttelsespraksis og levering af ydelser.	5.22	X	X	X
K23	<u>ISO 27001: Bilag A:</u> Der skal fastlægges processer for anskaffelse, brug, styring og afslutning af brugen af cloudtjenester i overensstemmelse med organisationens informationssikkerhedskrav. <u>FMI fortolkning:</u> Databehandleren skal fastlægge processer for anskaffelse, brug, styring og afslutning af brugen af cloudtjenester som skal godkendes af FMI forud for ibrugtagelsen af cloudtjenesten(/erne).	5.23	X	X	X
K24	<u>ISO 27001: Bilag A:</u> Organisationen skal planlægge og forberede sig på at håndtere informations-sikkerhedsincidents ved at definere, etablere og kommunikere processer, roller og ansvar for styring af informationssikkerhedsincidents. <u>FMI fortolkning:</u> Databehandleren skal have implementeret procedurer og processer for håndteringen af informationssikkerhedsincidents og persondatabrud ved at defi-	5.24	X	X	X

	nere, etablere og kommunikere processer, roller og ansvar for styring på tværs af dens organisation.				
K25	<u>ISO 27001: Bilag A:</u> Organisationen skal vurdere informationssikkerhedshændelser og beslutte, om de skal kategoriseres som informationssikkerhedsincidents. <u>FMI fortolkning:</u> Databehandleren skal vurdere informationssikkerhedshændelser samt persondatabrud og evaluere, hvorvidt de skal rapporteres til FMI.	5.25	X	X	X
K26	<u>ISO 27001: Bilag A:</u> Informationssikkerhedsincidents skal håndteres i overensstemmelse med de dokumenterede procedurer. <u>FMI fortolkning:</u> Informationssikkerhedsincidents og persondatabrud skal håndteres i overensstemmelse med de dokumenterede procedurer.	5.26	X	X	X
K27	<u>ISO 27001: Bilag A:</u> Den viden, der opnås i forbindelse med informationssikkerhedsincidents, skal anvendes til at styrke og forbedre foranstaltningerne for informationssikkerhed. <u>FMI fortolkning:</u> Den viden, der opnås i forbindelse med informationssikkerhedsincidents og persondatabrud, skal anvendes til at styrke og forbedre foranstaltningerne for informationssikkerhed og persondataskyttelse.	5.27	X	X	X
K28	<u>ISO 27001: Bilag A:</u> Organisationen skal definere og anvende procedurer til identifikation, indsamling, anskaffelse og opbevaring af bevismateriale i relation til informationssikkerhedshændelser.	5.28	X	X	X

	<u>FMI fortolkning:</u> Databehandleren skal definere og anvende procedurer til identifikation, indsamling, anskaffelse og opbevaring af bevismateriale i relation til informationssikkerhedshændelser og persondatabrud.				
K29	<u>ISO 27001: Bilag A:</u> Organisationen skal planlægge, hvordan informationssikkerheden opretholdes på et passende niveau under driftsforstyrrelser. <u>FMI fortolkning:</u> Databehandleren skal planlægge, hvordan informationssikkerheden og persondatabeskyttelsen opretholdes på et passende niveau under driftsforstyrrelser.	5.29	X	X	X
K30	IKT-parathed skal planlægges, implementeres, vedligeholdes og testes på grundlag af mål for business continuity og IKT kontinuitetskrav	5.30	X	X	X
K31	<u>ISO 27001: Bilag A:</u> Juridiske, lovmæssige, regulatoriske og kontraktlige krav, der er relevante for informationssikkerhed, samt organisationens tilgang til overholdelse af disse krav, skal være identificeret, dokumenteret og opdateret. <u>FMI fortolkning:</u> Juridiske, lovmæssige, regulatoriske og kontraktlige krav, der er relevante for informationssikkerhed og persondatabeskyttelse, samt Databehandlerens tilgang til sin overholdelse af disse krav, skal være identificeret, dokumenteret og opdateret.	5.31	X	X	X
K32	<u>ISO 27001: Bilag A:</u> Organisationen skal implementere passende procedurer til beskyttelse af intellektuelle ejendomsrettigheder.	5.32	X	X	X

	<u>FMI fortolkning:</u> Databehandleren skal implementere passende procedurer til beskyttelse af intellektuelle ejendomsrettigheder.				
K33	Optegnelser skal beskyttes mod tab, ødelæggelse, forfalskning, uautoriseret adgang og uautoriseret offentliggørelse.	5.33	X	X	X
K34	<u>ISO 27001: Bilag A:</u> Organisationen skal identificere og opfylde kravene vedrørende privatlivsbeskyttelse og beskyttelse af personoplysninger i henhold til gældende love og forskrifter samt kontraktlige krav. <u>FMI fortolkning:</u> Databehandleren skal identificere og opfylde kravene vedrørende privatlivsbeskyttelse og beskyttelse af personoplysninger i henhold til gældende love og forskrifter samt kontraktlige krav.	5.34	X	X	X
K35	<u>ISO 27001: Bilag A:</u> Organisationens tilgang til styring af informationssikkerhed og implementeringen heraf, herunder personer, processer og teknologier, skal vurderes uafhængigt og separat med planlagte mellemrum eller i tilfælde af væsentlige ændringer. <u>FMI fortolkning:</u> Databehandlerens tilgang til styring af informationssikkerhed og persondatabeskyttelse og implementeringen heraf, herunder personer, processer og teknologier, skal vurderes og dokumenteres med planlagte mellemrum eller i tilfælde af væsentlige ændringer.	5.35		X	X
K36	<u>ISO 27001: Bilag A:</u> Overensstemmelse med organisationens informationssikkerhedspolitik, emnespecifikke politikker, regler og standarder skal vurderes regelmæssigt.	5.36	X	X	X

	<u>FMI fortolkning:</u> Overensstemmelse med Databehand- lerens informationssikkerhedspolitik, privatlivspolitik, regler og standarder skal vurderes regelmæssigt.				
K37	<u>ISO 27001: Bilag A:</u> Driftsprocedurer for informationsbe- handlingssikkerhedsfaciliteter skal dokumenteres og gøres tilgængelige for medarbej- dere, der har brug for dem. <u>FMI fortolkning:</u> Driftsprocedurer for informations- og persondatabehandlingsfaciliteter skal dokumenteres og gøres tilgængelige for de af Databehandlerens medarbej- dere, der har brug for dem.	5.37	X	X	X

Personrelaterede foranstaltninger

Krav-ID	Krav	ISO27001-re- ference	Lavt risikoniveau	Mellem risikoniveau	Højt risikoniveau
K38	<u>ISO 27001: Bilag A:</u> Der skal udføres baggrundsverifikation af alle jobansøgere baggrund. Verifi- kationen skal foretages, inden de tiltræ- der i organisationen og løbende, under hensyntagen til love, forskrifter og eti- ske regler, og skal vurderes i forhold til organisationens krav, klassifikationen af den information, der skal gives ad- gang til, og de relevante risici. <u>FMI fortolkning:</u> Der skal udføres baggrundsverifikation af alle jobansøgere baggrund. Verifi- kationen skal foretages, inden de tiltræ- der i organisationen og løbende, under hensyntagen til love, forskrifter og eti- ske regler, og skal vurderes i forhold til FMI's krav, klassifikationen af de infor- mationer, der skal gives adgang til, og de relevante risici.	6.1		X	X

K39	<u>ISO 27001: Bilag A:</u> Ansættelseskontrakter skal beskrive medarbejderes og organisationens ansvar for informationssikkerhed. <u>FMI fortolkning:</u> Ansættelseskontrakter skal beskrive medarbejderes og Databehandlerens roller og ansvar for informationssikkerhed og persondatabeskyttelse.	6.2	X	X	X
K40	<u>ISO 27001: Bilag A:</u> Organisationens medarbejdere og relevante interessenter skal modtage passende awareness, uddannelse og træning vedrørende informationssikkerhed samt regelmæssige opdateringer om organisationens informationssikkerhedspolitik, emnespecifikke politikker og procedurer, hvor det er relevant for deres jobfunktion. <u>FMI fortolkning:</u> Databehandlerens medarbejdere og relevante interessenter skal modtage passende awareness, uddannelse og træning vedrørende informationssikkerhed og persondatabeskyttelse samt regelmæssige opdateringer om organisationens informationssikkerhedspolitik, privatlivspolitik og procedurer, hvor det er relevant for deres jobfunktion.	6.3	X	X	X
K41	<u>ISO 27001: Bilag A:</u> Der skal formaliseres og kommunikeres en sanktionsproces, så der iværksættes handlinger mod medarbejdere og andre relevante interessenter, som har overtrådt informationssikkerhedspolitikken. <u>FMI fortolkning:</u> Databehandleren skal formalisere og kommunikere en sanktionsproces, så der iværksættes handlinger mod med-	6.4	X	X	X

	arbejdere og andre relevante interessenter, som har overtrådt informations-sikkerhedspolitikken, privatlivspolitikken eller databehandlaftalen.				
K42	<u>ISO 27001: Bilag A:</u> Informationssikkerhedsansvar og -forpligtelser, som gælder efter ansættelsens ophør eller ændring, skal defineres, håndhæves og kommunikeres til relevante medarbejdere og andre interessenter. <u>FMI fortolkning:</u> Informationssikkerheds- og persondataskyttelsesansvar og -forpligtelser, som gælder efter ansættelsens ophør eller ændring, skal defineres, håndhæves og kommunikeres til relevante medarbejdere og andre interessenter.	6.5	X	X	X
K43	<u>ISO 27001: Bilag A:</u> Hemmeligholdelses- og fortrolighedsaftaler, der afspejler organisationens behov for at beskytte information, skal identificeres, dokumenteres, vurderes regelmæssigt og underskrives af medarbejdere og andre interessenter. <u>FMI fortolkning:</u> Hemmeligholdelses- og fortrolighedsaftaler, der afspejler FMI's behov for at beskytte informationer og personoplysninger, skal identificeres, dokumenteres, vurderes regelmæssigt og underskrives af medarbejdere og andre interessenter.	6.6	X	X	X
K44	<u>ISO 27001: Bilag A:</u> Der skal være implementerede sikkerhedstiltag, når medarbejdere arbejder på afstand, for at beskytte information, der er adgang til, og som behandles eller lagres uden for organisationens lokalteter.	6.7	X	X	X

	<u>FMI fortolkning:</u> Databehandleren skal have implementeret sikkerhedstiltag, når medarbejdere arbejder på afstand (fjernarbejde), for at beskytte informationer og personoplysninger, der er adgang til, og som behandles eller lagres uden for Databehandlerens eller FMI's lokaliteter.				
K45	<u>ISO 27001: Bilag A:</u> Organisationen skal sørge for, at medarbejdere kan indrapportere observerede eller formodede informationssikkerhedshændelser rettidigt via passende kanaler. <u>FMI fortolkning:</u> Databehandleren skal sørge for, at medarbejdere kan indrapportere observerede eller formodede informations-sikkerheds- og persondatabrudhændelser rettidigt via passende og vedligeholdte kanaler.	6.8	X	X	X

Fysiske foranstaltninger

Krav-ID	Krav	ISO27001-referenc	Lavt risikoniveau	Mellem risikoniveau	Højt risikoniveau
K46	<u>ISO 27001: Bilag A:</u> Der skal defineres og anvendes områdesikring til at beskytte områder, der indeholder information og understøttende aktiver. <u>FMI fortolkning:</u> Databehandleren skal definere, anvende og dokumentere områdesikring til at beskytte områder, der indeholder information og understøttende aktiver.	7.1		X	X
K47	Sikrede områder skal beskyttes ved hjælp af passende adgangsforanstaltninger og adgangspunkter.	7.2		X	X
K48	Fysisk sikring af kontorer, lokaler og faciliteter skal tilrettelægges og implementeres.	7.3		X	X

K49	Lokaliteter skal overvåges løbende for uautoriseret fysisk adgang.	7.4	X	X	X
K50	Beskyttelse mod fysiske og miljømæssige trusler, som fx naturkatastrofer og andre tilsigtede eller utilsigtede fysiske trusler mod infrastrukturen, skal tilrettelægges og implementeres.	7.5	X	X	X
K51	Sikkerhedsforhold for arbejde i sikrede områder skal tilrettelægges og implementeres.	7.6		X	X
K52	<u>ISO 27001: Bilag A:</u> Regler om at holde skriveborde ryddet for papir og bærbare lagringsmedier og om at holde skærme låst på informationsbehandlingsfaciliteter skal defineres og håndhæves på behørig vis. <u>FMI fortolkning:</u> Regler om at holde skriveborde ryddet for papir og bærbare lagringsmedier og om at holde skærme låst på informations- og persondatabehandlingsfaciliteter skal defineres og håndhæves på behørig vis.	7.7	X	X	X
K53	<u>ISO 27001: Bilag A:</u> Udstyr skal placeres på et sikkert og beskyttet sted. <u>FMI fortolkning:</u> Aktiver skal placeres på et sikkert og beskyttet sted.	7.8	X	X	X
K54	<u>ISO 27001: Bilag A:</u> Aktiver uden for organisationens lokationer skal beskyttes. <u>FMI fortolkning:</u> Aktiver uden for Databehandlerens lokationer skal beskyttes.	7.9		X	X
K55	<u>ISO 27001: Bilag A:</u> Lagringsmedier skal styres i hele deres livscyklus i forbindelse med anskaffelse, brug, transport og bortskaffelse i	7.10	X	X	X

	overensstemmelse med organisationsklassifikationssystem og krav til håndtering. <u>FMI fortolkning:</u> Lagringsmedier skal styres i hele deres livscyklus i forbindelse med anskaffelse, brug, transport og bortskaffelse i overensstemmelse med FMI's krav til håndtering.				
K56	<u>ISO 27001: Bilag A:</u> Informationsbehandlingsfaciliteter skal beskyttes mod strømsvigt og andre forstyrrelser som følge af svigt af understøttende forsyninger. <u>FMI fortolkning:</u> Informations- og persondatabehandlingsfaciliteter skal beskyttes mod strømsvigt og andre forstyrrelser som følge af svigt af understøttende forsyninger.	7.11		X	X
K57	Kabler, som bærer strøm, data eller understøtter informationstjenester, skal beskyttes mod aflytning, forstyrrelse og beskadigelse.	7.12		X	X
K58	<u>ISO 27001: Bilag A:</u> Udstyr skal vedligeholdes korrekt for at sikre tilgængelighed, integritet og fortrolighed af information. <u>FMI fortolkning:</u> Aktiver skal vedligeholdes korrekt for at sikre tilgængelighed, integritet og fortrolighed af information og personoplysninger.	7.13	X	X	X
K59	<u>ISO 27001: Bilag A:</u> Udstyr med lagringsmedier skal verificeres for at sikre, at følsomme data og licensbeskyttet software slettes eller overskrives på forsvarlig vis inden bortskaffelse eller genbrug.	7.14	X	X	X

	<u>FMI fortolkning:</u> Aktiver med lagringsmedier skal verificeres for at sikre, at følsomme data og licensbeskyttet software slettes eller overskrives på forsvarlig vis inden bortskaffelse eller genbrug.				
--	---	--	--	--	--

Teknologiske foranstaltninger

Krav-ID	Krav	ISO27001-referenc	Lavt risikoniveau	Mellem risikoniveau	Højt risikoniveau
K60	<u>ISO 27001: Bilag A:</u> Information, der lagres på, behandles af eller er tilgængelig via brugerenheder, skal beskyttes. <u>FMI fortolkning:</u> Informationer og personoplysninger, der lagres på, behandles af eller er tilgængelig via brugerenheder, skal beskyttes.	8.1	X	X	X
K61	Tildeling og anvendelse af privilegerede adgangsrettigheder skal begrænses og styres.	8.2	X	X	X
K62	<u>ISO 27001: Bilag A:</u> Adgang til information og understøttende aktiver skal begrænses i overensstemmelse med den fastlagte emnespecifikke politik for administration af adgang. <u>FMI fortolkning:</u> Adgang til informationer, personoplysninger og understøttende aktiver skal begrænses i overensstemmelse med den fastlagte emnespecifikke politik for administration af adgang.	8.3	X	X	X
K63	Adgang til at læse og skrive kildekode, udviklingsværktøjer og softwarebiblioteker skal håndteres på en hensigtsmæssig måde.	8.4	X	X	X

K64	Der skal implementeres sikre autentifikations teknologier og -procedurer på baggrund af begrænsninger i informationsadgangen og den emnespecifikke politik for administration af adgang.	8.5	X	X	X
K65	Anvendelsen af ressourcer skal overvåges og tilpasses i overensstemmelse med de nuværende og forventede kapacitetskrav. <u>FMI fortolkning:</u> (Læs pkt. 8.6 i ISO 27002 for en uddybning af kravene)	8.6	X	X	X
K66	<u>ISO 27001: Bilag A:</u> Beskyttelse mod malware skal implementeres og understøttes af passende awareness hos brugeren. <u>FMI fortolkning:</u> Databehandleren skal sikre at der implementeres passende beskyttelse mod cyberkriminalitet, herunder bl.a. men ikke begrænset til Malware, Phishing, Virus, Intern lækage. Herudover skal Databehandleren sikre, at der udføres passende awareness for dens ansatte for at mindske sandsynligheden for at cyberkriminalitet lykkes.	8.7	X	X	X
K67	<u>ISO 27001: Bilag A:</u> Der skal indhentes informationer om tekniske sårbarheder i anvendte informationssystemer, organisationens eksponering for sådanne sårbarheder skal evalueres, og der skal iværksættes passende tiltag. <u>FMI fortolkning:</u> Der skal indhentes informationer om tekniske sårbarheder i anvendte informationssystemer, Databehandlerens eksponering for sådanne sårbarheder skal evalueres, og der skal iværksættes passende tiltag.	8.8	X	X	X

K68	Konfigurationer, herunder sikkerheds-konfigurationer, af hardware, software, tjenester og netværk skal etableres, dokumenteres, implementeres, overvåges og vurderes.	8.9	X	X	X
K69	<u>ISO 27001: Bilag A:</u> Information lagret i informationssystemer, enheder eller i andre lagringsmedier skal slettes, når der ikke længere er brug for den. <u>FMI fortolkning:</u> Databehandleren skal implementere procedurer og processer vedrørende løbende sletningen af informationer og personoplysninger. Disse procedurer og processer skal dække over samtlige aktiver der indeholder informationer og personoplysninger delt af FMI, og skal som minimum tage effekt på det tidspunkt, hvor informationerne og personoplysningerne ikke længere er nødvendige for Databehandlerens behandling på vegne af FMI.	8.10	X	X	X
K70	<u>ISO 27001: Bilag A:</u> Datamaskering skal anvendes i overensstemmelse med organisationens emnespecifikke politik for administration af adgang og andre relaterede emnespecifikke politikker samt forretningsmæssige krav under hensyntagen til gældende lovgivning. <u>FMI fortolkning:</u> Databehandleren skal anvende datamaskering (pseudonymisering og anonymisering) i overensstemmelse med Databehandlerens emnespecifikke politik for administration af adgang, privatlivspolitik samt, når dette er påkrævet/instrueret af FMI eller påkrævet under hensyntagen til gældende lovgivning.	8.11	X	X	X

K71	<u>ISO 27001: Bilag A:</u> Der skal benyttes tiltag til at forebygge datalækage i systemer, netværk og andre enheder, der behandler, lagrer eller transmitterer følsom information. <u>FMI fortolkning:</u> Der skal benyttes tiltag til at forebygge datalækage i systemer, netværk og andre enheder, der behandler, lagrer eller transmitterer følsomme informationer og/eller personoplysninger.	8.12	X	X	X
K72	<u>ISO 27001: Bilag A:</u> Backup af information, software og systemer skal vedligeholdes og testes regelmæssigt i overensstemmelse med den aftalte emnespecifikke politik for backup. <u>FMI fortolkning:</u> Backup af information, software og systemer skal vedligeholdes og testes regelmæssigt.	8.13	X	X	X
K73	<u>ISO 27001: Bilag A:</u> Informationsbehandlingsfaciliteter skal implementeres med tilstrækkelig redundans til at kunne imødekomme tilgængelighedskrav. <u>FMI fortolkning:</u> Informations- og persondatabehandlingsfaciliteter skal implementeres med tilstrækkelig redundans til at kunne imødekomme tilgængelighedskrav.	8.14	X	X	X
K74	<u>ISO 27001: Bilag A:</u> Logge, der optegner aktiviteter, undtagelser, fejl og andre relevante hændelser, skal udarbejdes, opbevares, beskyttes og analyseres. <u>FMI fortolkning:</u> Databehandleren skal implementere passende logning-systemer, der opteg-	8.15	X	X	X

	ner aktiviteter og advarer mod undtagelser, fejl og andre relevante hændelser. Disse logs skal udarbejdes, opbevares, beskyttes og analyseres regelmæssigt af Databehandleren med henblik på at sikre informations- og persondatasikkerheden, og eventuelt implementere yderligere sikkerhedstiltag.				
K75	<u>ISO 27001: Bilag A:</u> Netværk, systemer og applikationer skal overvåges for unormal adfærd, og der skal iværksættes passende handlinger for at evaluere potentielle informationssikkerhedsincidents. <u>FMI fortolkning:</u> Netværk, systemer og applikationer skal overvåges for unormal adfærd, og der skal iværksættes passende handlinger for at evaluere potentielle informationssikkerhedsincidents og persondatabrud.	8.16	X	X	X
K76	<u>ISO 27001: Bilag A:</u> Urene i systemer til informationsbehandling, som organisationen anvender, skal synkroniseres med godkendte tidskilder <u>FMI fortolkning:</u> Urene i systemer til informations- og persondatabehandling, som organisationen anvender, skal synkroniseres med FMI-godkendte tidskilder.	8.17	X	X	X
K77	<u>ISO 27001: Bilag A:</u> Brugen af understøttende programmer, der kan omgå system- og applikationsforanstaltninger, skal begrænses og styres effektivt. <u>FMI fortolkning:</u> Brugen af understøttende programmer, der kan omgå system- og applikationsforanstaltninger, kræver FMI's godkendelse forud for dets implementering og	8.18	X	X	X

	anvendelse. Hertil er der et krav om, at Databehandleren skal sikre, at det anvendte programmel styres effektivt og kun anvendes af forudgående godkendte medarbejdere.				
K78	Der skal implementeres procedurer og tiltag til sikker styring af softwareinstallationer i test- og produktionssystemer.	8.19	X	X	X
K79	<u>ISO 27001: Bilag A:</u> Netværk og netværksenheder skal sikres, styres og kontrolleres for at beskytte information i systemer og applikationer. <u>FMI fortolkning:</u> Netværk og netværksenheder skal sikres, styres og kontrolleres for at beskytte informationer og personoplysninger i systemer og applikationer.	8.20	X	X	X
K80	Sikkerhedsmekanismer, serviceniveauer og servicekrav til netværkstjenester skal identificeres, implementeres og overvåges.	8.21	X	X	X
K81	Grupper af informationstjenester, brugere og informationssystemer skal adskilles i organisationens netværk.	8.22	X	X	X
K82	Adgang til eksterne websites skal styres for at reducere eksponering for skadeligt indhold.	8.23	X	X	X
K83	Regler for effektiv anvendelse af kryptografi, herunder administration af krypteringsnøgler, skal defineres og implementeres.	8.24		X	X
K84	Der skal fastlægges og anvendes regler for sikker udvikling af software og systemer.	8.25	X	X	X
K85	<u>ISO 27001: Bilag A:</u> Informationssikkerhedskrav skal identificeres, specificeres og godkendes ved udvikling eller anskaffelse af applikationer.	8.26	X	X	X

	<u>FMI fortolkning:</u> Informations- og persondatasikkerhedskrav skal identificeres, specificeres og godkendes ved udvikling eller anskaffelse af applikationer.				
K86	Principper for udvikling af sikre systemer skal fastlægges, dokumenteres, vedligeholdes og anvendes i forbindelse med udvikling af informationssystemer.	8.27	X	X	X
K87	Principper for sikker programmering skal anvendes ved softwareudvikling.	8.28	X	X	X
K88	<u>ISO 27001: Bilag A:</u> Processer til sikkerhedstest skal defineres og implementeres i udviklingslivscyklussen. <u>FMI fortolkning:</u> Processer til sikkerhedstest skal defineres og implementeres i udviklings- og vedligeholdelsescyklussen.	8.29		X	X
K89	<u>ISO 27001: Bilag A:</u> Organisationen skal lede, overvåge og vurdere de aktiviteter, der er forbundet med outsourcet systemudvikling. <u>FMI fortolkning:</u> Databehandleren skal lede, overvåge og vurdere de aktiviteter, der er forbundet med outsourcet systemudvikling.	8.30	X	X	X
K90	Udviklings-, test- og produktionsmiljøer skal adskilles og sikres.	8.31	X	X	X
K91	<u>ISO 27001: Bilag A:</u> Ændringer til informationsbehandlingsfaciliteter og informationssystemer skal være underlagt procedurer for ændringsstyring. <u>FMI fortolkning:</u> Ændringer til informations- og persondatabehandlingsfaciliteter og informationssystemer skal være underlagt procedurer for ændringsstyring og skal dokumenteres.	8.32	X	X	X

K92	<u>ISO 27001: Bilag A:</u> Information til brug for test skal udvælg- ges, beskyttes og styres på passende vis. <u>FMI fortolkning:</u> Databehandleren skal, med mindre det er umuligt, kun anvende dummy- data/opdigtet data til brug for tests. Alle ægte/faktiske informationer og person- oplysninger til brug for test skal udvælg- ges, beskyttes og styres på passende vis.	8.33	X	X	X
K93	<u>ISO 27001: Bilag A:</u> Audit og andre sikringsaktiviteter, der indebærer vurdering af test- og produk- tionssystemer, skal planlægges og af- tales mellem vedkommende, der udfør- rer testen, og den relevante ledelse. <u>FMI fortolkning:</u> Tilsyn og andre sikringsaktiviteter, der indebærer vurdering af test- og produk- tionssystemer, skal planlægges og af- tales mellem vedkommende, der udfør- rer testen, og den relevante ledelse.	8.34	X	X	X

Bilag F Yderligere sikkerhedskrav til databehandling
(ISO 27701 refererer til ISO 27701/2025)
Generelle rettelser til ISO 27701

Organisation = Databehandler

Kunden = FMI

Betingelser for indsamling og behandling

Krav-ID	Krav	ISO27701-referance	Lavt risikoniveau	Mellem risikoniveau	Højt risikoniveau
K94	Databehandleren skal, hvor det er relevant, sikre, at aftalen om behandling af personoplysninger adresserer Databehandlerens rolle i forbindelse med at yde assistance med FMI's forpligtelser (idet der tages hensyn til behandlingens art og den information, der er tilgængelig for Databehandleren).	A.2.2.2	X	X	X
K95	Databehandleren skal sikre, at personoplysninger, der behandles på vegne af FMI, kun behandles med de formål, som er angivet i FMI's dokumenterede instrukser.	A.2.2.3	X	X	X
K96	Databehandleren må ikke anvende personoplysninger, der er behandlet i henhold til en aftale med henblik på markedsføring og reklamer, uden at få klarlagt, om der er opnået forudgående samtykke fra den relevante registrerede. Databehandleren må ikke gøre et sådant samtykke betinget af, at ydelserne modtages.	A.2.2.4	X	X	X
K97	Databehandleren skal informere FMI, hvis en behandlingsinstruks efter Databehandlerens skøn overtræder gældende lovgivning og/eller forordninger. (Omfattet af Databehandleraftalen)	A.2.2.5	X	X	X
K98	Databehandleren skal give FMI den relevante information, således at FMI kan påvise overensstemmelse med deres forpligtelser.	A.2.2.6	X	X	X

K99	ISO 27701: Bilag A: Organisationen skal fastlægge og føre de nødvendige registreringer for at bevise, at den opfylder sine forpligtelser (som specificeret i den gældende aftale) i relation til behandling af personoplysninger på vegne af en kunde. FMI fortolkning: Databehandleren skal fastlægge og føre de nødvendige registreringer for at bevise, at den opfylder sine forpligtelser (som specificeret i den gældende databehandleraftale) i relation til behandling af personoplysninger på vegne af FMI.	A.2.2.7	X	X	X
-----	---	---------	---	---	---

Forpligtelser over for de registrerede

Krav-ID	Krav	ISO27701-referance	Lavt risikoniveau	Mellem risikoniveau	Højt risikoniveau
K100	Databehandleren skal give FMI mulighed for at opfylde sine forpligtelser i relation til de registrerede.	A.2.3.2	X	X	X

Privacy by design and privacy by default

Krav-ID	Krav	ISO27701-referance	Lavt risikoniveau	Mellem risikoniveau	Højt risikoniveau
K101	Databehandleren skal sikre, at midlertidige filer, der dannes som følge af behandling af personoplysninger, bortskaffes (fx slettes eller destrueres) efter dokumenterede procedurer inden for en specificeret, dokumenteret periode.	A.2.4.2	X	X	X
K102	Databehandleren skal give mulighed for at tilbagelevere, overføre og/ eller bortskaffe personoplysninger på en sikker måde. Den skal også gøre sin politik tilgængelig for FMI.	A.2.4.3	X	X	X
K103	Databehandleren skal lade personoplysninger, der overføres via et data-transmissionsnet, underkaste passende foranstaltninger for at sikre, at dataene kommer frem til den tilsigtede destination.	A.2.4.4	X	X	X

Deling, overførsel og videregivelse af personoplysninger

Krav-ID	Krav	ISO27701-referance	Lavt risikoniveau	Mellem risikoniveau	Højt risikoniveau
K104	Databehandleren skal rettidigt informere FMI om grundlaget for overførsel af personoplysninger mellem jurisdiktioner og om eventuelle tilsigtede ændringer i denne henseende, således at FMI har mulighed for at gøre indsigelse mod sådanne ændringer eller ophæve aftalen.	A.2.5.2	X	X	X
K105	Databehandleren skal specificere og dokumentere, hvilke lande og internationale organisationer personoplysninger kan overføres til.	A.2.5.3	X	X	X
K106	Databehandleren skal registrere videregivelse af personoplysninger til tredjeparter, herunder hvilke personoplysninger der er videregivet, til hvem og hvornår.	A.2.5.4	X	X	X
K107	Databehandleren skal underrette FMI om eventuelle juridisk bindende anmodninger om videregivelse af personoplysninger. (Omfattet af Databehandleraftalen)	A.2.5.5	X	X	X
K108	Databehandleren skal afvise eventuelle anmodninger om videregivelse af personoplysninger, som ikke er juridisk bindende, rådføre sig med FMI, før den videregiver personoplysninger og accepterer aftalemæssigt aftalte anmodninger om videregivelse af personoplysninger, som er autoriseret af FMI.	A.2.5.6	X	X	X
K109	Databehandleren skal oplyse, hvis den benytter underleverandører til behandling af personoplysninger, før det sker. (Omfattet af Databehandleraftalen)	A.2.5.7	X	X	X
K110	<u>ISO 27701: Bilag A:</u> Organisationen må kun benytte en underleverandør til at behandle personoplysninger i overensstemmelse med kundeaftalen.	A.2.5.8	X	X	X

	<u>FMI fortolkning:</u> Databehandleren må kun benytte en underleverandør til at behandle personoplysninger i overensstemmelse med databehandleraftalen.				
K111	Databehandleren skal, hvis den har en generel skriftlig bemyndigelse, informere FMI om eventuelle tilsigtede ændringer vedrørende tilføjelse eller udskiftning af underleverandører til at behandle personoplysninger, hvorved FMI får mulighed for at gøre indsigelser mod sådanne ændringer. (Omfattet af Databehandleraftalen)	A.2.5.9	X	X	X